MEDTRACARE

Digitales Patientenportal & CRM-Integration

Implementierungsplan – Odoo 17 · IONOS VPS · DSGVO-konform

ERSTELLT VON	DATUM
[Ihr Name]	20. April 2026
VERSION	STATUS
1.0	Zur Prüfung

🔒 DSGVO-konform · Server in Deutschland · Open-Source-Stack

📋 Inhaltsverzeichnis

1. **Projektzusammenfassung**
2. **Gesamtarchitektur**
3. **Patient Journey – Prozessablauf** (7 Phasen)
4. **Technischer Stack**
5. **Detaillierte Implementierungsschritte**
   - Phase 0: Infrastruktur & Setup
   - Phase 1: Odoo CRM Konfiguration
   - Phase 2: Patientenportal (Frontend)
   - Phase 3: Backend API & Integration
   - Phase 4: DSGVO-Compliance
   - Phase 5: Treueprogramm-Logik
   - Phase 6: Erweiterbarkeit & APIs
6. **Projektplan & Zeitstrahl** (8 Wochen)
7. **Liefergegenstände**
8. **Datensicherheit & Backup**
9. **Rollen & Zugriffsrechte**
10. **Mitwirkungspflichten des Auftraggebers**
11. **Risiken & Gegenmaßnahmen**
12. **Kostenübersicht**
13. **Über mich**
14. **Nächste Schritte**

1. Projektzusammenfassung

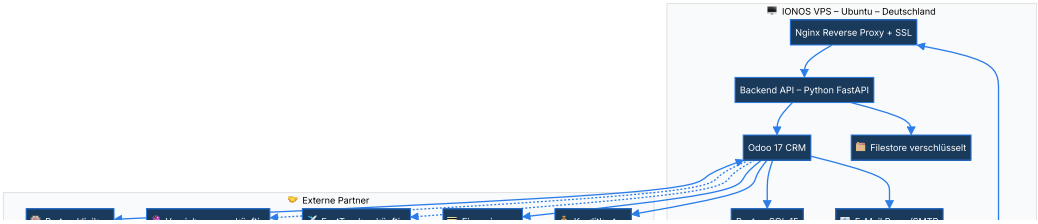
Ziel dieses Projektes ist die Entwicklung einer vollständig digitalen, DSGVO-konformen Lösung für MedTraCare, die alle Schritte des Patientenprozesses – von der ersten Datenerfassung bis zur Auszahlung des Treueprogramms – digital, nachvollziehbar und rechtssicher abbildet.

- ✓ Patienten eine strukturierte Möglichkeit bieten, Klinikdokumente hochzuladen und Daten zu erfassen
- ✓ Alle Patientenvorgänge automatisch in ein zentrales Odoo-CRM übertragen
- ✓ Mitarbeiter durch einen klaren, nachvollziehbaren Workflow unterstützen
- ✓ Treueprogramme (Finanzierung, Cashback, Kreditkarte) vollständig abwickeln
- ✓ Automatisierte, rechtssichere E-Mail-Kommunikation mit dem Patienten sicherstellen
- ✓ System jederzeit erweiterbar gestalten (API-Anbindungen, Partner-Schnittstellen)

Die gesamte Infrastruktur wird auf einem **IONOS VPS (Ubuntu 22.04 LTS)** in Deutschland betrieben und entspricht vollständig der **DSGVO**.

2. Gesamtarchitektur

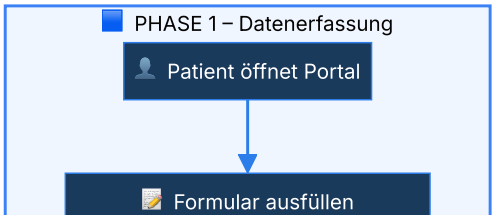
ABB. 1 – SYSTEMARCHITEKTUR



3. Patient Journey – Prozessablauf (7 Phasen)

Die folgende Darstellung zeigt den vollständigen Patientenprozess von der ersten Dateneingabe bis zur Treueprogramm-Auszahlung. Jede Phase ist farblich hervorgehoben.

ABB. 2 – VOLLSTÄNDIGER PATIENTENPROZESS



4. Technischer Stack

Komponente	Technologie	Begründung
Webserver	Nginx	Reverse Proxy, SSL-Terminierung, hohe Performance
SSL-Zertifikat	Let's Encrypt (Certbot)	Kostenfrei, automatisch erneuert, DSGVO-konform
Backend API	Python 3.12 + FastAPI	Modern, schnell, ideal für Odoo XML-RPC Integration
CRM	Odoo 17 Community	Open Source, vollständig anpassbar, DSGVO-konform
Datenbank	PostgreSQL 15	Enterprise-grade, nativ von Odoo verwendet
Datei-Speicher	Odoo Filestore (verschlüsselt)	Dokumente direkt im CRM verknüpft und gesichert
E-Mail	Brevo / SendGrid + SMTP	Zuverlässige Zustellung, DSGVO-konform, EU-Server
Server	IONOS VPS – Ubuntu 22.04 LTS	Rechenzentrum Deutschland, DSGVO, IONOS SLA
Backup	IONOS Snapshots + pg_dump	Tägliche Sicherung, Off-Site auf Object Storage
Monitoring	Uptime Kuma / Netdata	Systemüberwachung, Alarmierung per E-Mail
Sicherheit	Fail2Ban, UFW, ClamAV	Brute-Force-Schutz, Firewall, Virenscan

5. Detaillierte Implementierungsschritte

Phase 0 – Infrastruktur & Setup (Woche 1)

- [ ] IONOS VPS bestellen und Ubuntu 22.04 LTS installieren
- [ ] Server-Hardening: SSH-Key-Only, Fail2Ban, UFW-Firewall konfigurieren
- [ ] Nginx installieren, virtuellen Host und SSL (Let's Encrypt) einrichten
- [ ] PostgreSQL 15 installieren, Odoo-Datenbankbenutzer anlegen
- [ ] Odoo 17 Community installieren und Grundkonfiguration vornehmen
- [ ] Backup-Strategie einrichten (täglich, IONOS Object Storage)

Phase 1 – Odoo CRM Konfiguration (Woche 1–2)

1.1 BENUTZERDEFINIERTES PATIENTENMODELL (`MEDTRACARE_PATIENT`)

Feld	Typ	Beschreibung
`partner_first_name`	Char	Vorname (Pflicht)
`partner_last_name`	Char	Nachname (Pflicht)
`partner_address`	Text	Anschrift (Pflicht)
`partner_email`	Char	E-Mail (Pflicht, validiert)
`partner_phone`	Char	Telefon (Pflicht)
`clinic_id`	Many2one → res.partner	Behandelnde Klinik (nur Partnerkliniken)
`treatment_ids`	Many2many → med.treatment	Behandlungsarten (max. 3)
`surgery_date`	Date	OP-Datum (Pflicht)
`clinic_offer`	Binary / Attachment	Upload Klinikangebot
`treatment_contract`	Binary / Attachment	Upload Behandlungsvertrag
`gdpr_consent`	Boolean	DSGVO-Einwilligung (Pflicht)
`gdpr_consent_date`	Datetime	Zeitstempel + IP der Einwilligung
`loyalty_choice`	Selection (A/B/C)	Treueprogramm-Auswahl
`payment_link`	Char	Externer Zahlungslink der Klinik
`passport_data`	Text (verschlüsselt)	Reispassdaten
`flight_data`	Text	Flugdaten (für FastTrack)
`stage_id`	Many2one → crm.stage	Status-Workflow

1.2 CRM STATUS-WORKFLOW (KANBAN)

Neu	In Prüfung	Vollständig	Leistungen gebucht	Zahlungslink gesendet	Zahlung eingegangen	Behandlung abge

1.3 AUTOMATISIERTE E-MAIL-VORLAGEN (6 STÜCK)

#	Vorlage	Trigger
1	Eingangsbestätigung	Formular-Übermittlung
2	Zusatzleistungs-E-Mail mit Optionen A/B/C	Status → "Vollständig"
3	Zahlungslink-E-Mail	Zahlungslink eingetragen
4	Finale Buchungsbestätigung	Status → "Zahlung eingegangen"
5	Abschluss-E-Mail + Bewertungslink	Status → "Abgeschlossen"
6	Nachfrage bei unvollständigen Daten	Manuell durch Mitarbeiter

Phase 2 – Patientenportal / Frontend (Woche 2–3)

Das Patientenportal wird als responsives, mehrstufiges Webformular (Wizard) entwickelt:

Stufe	Inhalt
Stufe 1	Persönliche Daten: Vorname, Nachname, Anschrift, E-Mail, Telefon
Stufe 2	Behandlungsdaten: Klinik (Dropdown), Behandlungsarten (max. 3), OP-Datum
Stufe 3	Dokument-Upload: Klinikangebot + Behandlungsvertrag (PDF/JPG/PNG, max. 10 MB)
Stufe 4	DSGVO-Einwilligung (aktive Checkbox, nicht vorausgefüllt) + Absenden

UX-Features: Fortschrittsbalken · Echtzeit-Validierung · Ladeanimation · Datei-Vorschau · Mobil-optimiert

Phase 3 – Backend API & Odoo-Integration (Woche 3–4)

REST API ENDPUNKTE

Endpunkt	Methode	Beschreibung
`/api/patient/submit`	POST	Patientendaten + Dateien übermitteln
`/api/patient/clinics`	GET	Liste der Partnerkliniken
`/api/patient/treatments`	GET	Liste der Behandlungsarten
`/api/patient/loyalty`	POST	Treueprogramm-Wahl speichern
`/api/patient/status/{id}`	GET	(Optional) Patientenstatus abfragen

SICHERHEITSMASSNAHMEN BEIM DATEI-UPLOAD

- ☐ Virenscan aller hochgeladenen Dateien (ClamAV)
- ☐ Strikte MIME-Type-Prüfung (nur PDF, JPG, PNG)
- ☐ Maximale Dateigröße: 10 MB
- ☐ reCAPTCHA zum Schutz vor Missbrauch
- ☐ Dateien ausschließlich im Odoo Filestore – nie auf Webserver

DSGVO-Compliance

⚠️ **WICHTIG:** DSGVO-Konformität wird als nicht verhandelbare Anforderung behandelt und ist in *allen* Architekturebenen implementiert.

Maßnahme	Implementierung
Einwilligung	Aktive Checkbox mit Zeitstempel + IP-Adresse (nicht vorausgefüllt)
Datenminimierung	Nur für den Prozess notwendige Felder werden erfasst
Verschlüsselung	HTTPS (TLS 1.3) für alle Verbindungen; verschlüsselter Filestore
Serverstandort	IONOS Rechenzentrum Deutschland (Frankfurt / Karlsruhe)
Datenlöschung	Löschkonzept: Inaktive Vorgänge nach gesetzlicher Frist löschbar
Zugriffskontrolle	Rollenbasierter Zugriff in Odoo – nur autorisierte Mitarbeiter
Audit-Log	Vollständige Nachverfolgung aller Änderungen im Odoo Chatter
Datenportabilität	Export von Patientendaten auf Anfrage möglich
AVV-Verträge	Auftragsverarbeitungsverträge mit IONOS und allen API-Partnern
Datenschutzerklärung	Rechtskonforme DSE im Portal verlinkt (vom Anwalt zu prüfen)

Treueprogramm-Logik

A

Finanzierung

0% Zinsen – Weiterleitung zu Finanzierungspartner-Antragsstrecke per E-Mail-Link

B

5% Treuepräme

Auszahlung per Banküberweisung nach Provisionseingang der Klinik

C

10% Kreditkarte

Prepaid-Kreditkarte mit 10% Startguthaben über Kreditkarten-Partner

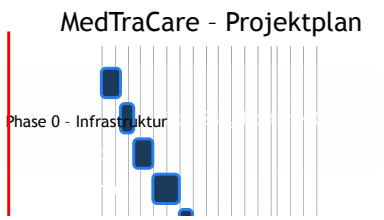
Erweiterbarkeit (API-Schnittstellen)

Partner	Schnittstelle	Status
Versicherungspartner	REST API	Geplant – Phase 2
FastTrack-Anbieter	REST API	Geplant – Phase 2
Flughafen-Lounge	REST API	Geplant – Phase 2
Finanzierungspartner	REST API / OAuth2	Geplant – Phase 2
Kreditkarten-Anbieter	REST API	Geplant – Phase 2

Partner	Schnittstelle	Status
Google Reviews	REST API	Geplant – Phase 2
Trustpilot	REST API	Geplant – Phase 2

6. Projektplan & Zeitstrahl (8 Wochen)

ABB. 3 – PROJEKT-TIMELINE



Gesamtdauer: ca. 8 Wochen (abhängig von Feedback-Zyklen und Drittanbieter-Zugängen)

7. Liefergegenstände

01
Produktive Odoo-Instanz
Vollständig konfiguriert auf IONOS VPS, SSL, Backup

02
Odoo-Modul
medtracare_patient: Felder, Workflows, Automationen

03
Patientenportal
Responsives Webformular mit Upload & DSGVO

04
Backend API
FastAPI-Service für Odoo-Integration & Datei-Handling

05
6 E-Mail-Vorlagen
Automatisierte Odoo-E-Mails für alle Prozessschritte

06
DSGVO-Dokumentation
Verarbeitungsverzeichnis, Einwilligungsprotokoll

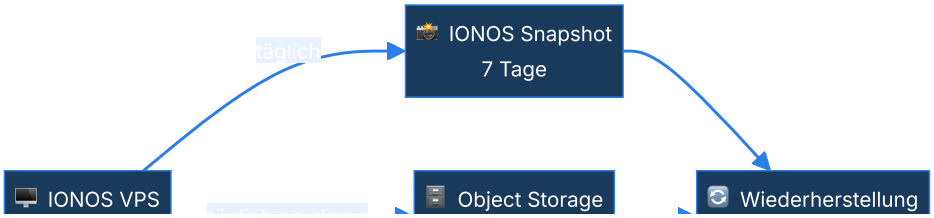
07
Systemdokumentation
Technische & Benutzer-Dokumentation auf Deutsch

08
Mitarbeiter-Schulung
2-stündige Online-Schulung nach Go-Live

09
4 Wochen Support
Nachbetreuung nach Go-Live, Fehlerbehebung

8. Datensicherheit & Backup

ABB. 4 – BACKUP-STRATEGIE



Kennzahl	Zielwert
Recovery Time Objective (RTO)	< 2 Stunden
Recovery Point Objective (RPO)	< 24 Stunden
Backup-Aufbewahrung Server-Snapshot	7 Tage
Backup-Aufbewahrung Datenbank & Dateien	30 Tage
Serverstandort	Deutschland (IONOS)

9. Rollen & Zugriffsrechte in Odoo

Rolle	Zugriffsrechte
Patient (extern)	Nur Formular-Übermittlung via Portal – kein direkter CRM-Zugang
Mitarbeiter	Lesen/Schreiben eigener Vorgänge, E-Mails senden, Status ändern
Manager	Voller Zugriff, Berichte, Klinikpartner verwalten
Administrator	Systemkonfiguration, Benutzerverwaltung

10. Mitwirkungspflichten des Auftraggebers

Für eine reibungslose Umsetzung werden folgende Informationen und Zugänge frühzeitig benötigt:

- ☐ Zugangsdaten zum IONOS VPS (oder gemeinsame Bestellung)
- ☐ Vollständige Liste aller Partnerkliniken (für Dropdown im Formular)
- ☐ Vollständige Liste aller Behandlungsarten (für Dropdown)

- ☐ Logo, Farben und Design-Vorgaben für das Patientenportal
- ☐ Rechtsgültige Datenschutzerklärung und AGB (vom Rechtsanwalt geprüft)
- ☐ Kontaktdaten des Datenschutzbeauftragten (falls vorhanden)
- ☐ Zugangsdaten / Kontakt zum Finanzierungspartner und Kreditkarten-Anbieter
- ☐ E-Mail-Texte für alle 6 Automations-E-Mails (oder Texterstellung gewünscht?)
- ☐ Genaue Spezifikation der Reisepass- und Flugdaten-Felder

11. Risiken & Gegenmaßnahmen

Risiko	Wahrscheinlichkeit	Gegenmaßnahme
Verzögerung durch Drittanbieter-API-Zugänge	Mittel	Manuelle Fallback-Prozesse im CRM
Datenschutzrechtliche Änderungen (DSGVO)	Gering	Modulare, erweiterbare DSGVO-Implementierung
Serverausfall / Downtime	Gering	Automatisches Monitoring + IONOS SLA 99,9%
Missbrauch des Upload-Formulars	Mittel	reCAPTCHA, ClamAV Virenscan, Rate Limiting
Scope Creep / Anforderungsänderungen	Mittel	Schriftliches Change-Management-Verfahren

12. Kostenübersicht (Schätzung laufende Kosten)

Position	Einmalig	Monatlich
IONOS VPS (4 vCPU, 8 GB RAM, 100 GB SSD)	–	~20–30 €
SSL-Zertifikat (Let's Encrypt)	0 €	0 €
Odoo 17 Community (Open Source)	0 €	0 €
E-Mail-Dienst (Brevo Starter)	–	0–15 €
IONOS Object Storage (Backup)	–	~5 €
Entwicklungskosten	**[auf Anfrage]**	–
Gesamt laufende Kosten	–	**ca. 25–50 €/Monat**

13. Warum ich der richtige Partner bin

Kompetenz	Details
🐍 **Odoo-Expertise**	Mehrjährige Erfahrung in Odoo-Customizing, Modulentwicklung und Workflow-Automation
🔒 **DSGVO-Kenntnisse**	Praktische Erfahrung mit datenschutzkonformen Webapplikationen für den deutschen Markt

Kompetenz	Details
⚙️ **Full-Stack-Entwicklung**	Von Backend-API (FastAPI/Python) bis responsivem Frontend
🖥️ **Linux-Administration**	IONOS/Ubuntu-Deployments, Nginx, SSL, Backup, Server-Hardening
🗣️ **Kommunikation**	Regelmäßige Status-Updates, transparente Arbeitsweise, Dokumentation auf Deutsch
📅 **Verfügbarkeit**	[Ihre Verfügbarkeit eintragen]

14. Nächste Schritte

1. **Kick-off-Gespräch** – Offene Fragen klären, Anforderungen finalisieren (ca. 1 Stunde)
2. **Anforderungs-Workshop** – Behandlungsarten, Kliniken, E-Mail-Texte und Design definieren
3. **Vertragsabschluss** – Projektvertrag mit klarem Leistungsumfang und Meilensteinen
4. **Server-Bestellung** – IONOS VPS gemeinsam bestellen oder Zugang übermitteln
5. **Projektstart** – Phase 0 beginnt, wöchentliche Status-Updates

[Ihr Name] | [Ihre E-Mail] | [Ihr Malt-Profil]

Dieses Dokument wurde auf Basis der bereitgestellten Projektbeschreibung erstellt und kann nach dem Kick-off-Gespräch präzisiert werden.

Version 1.0 · 20. April 2026 · Vertraulich